

## 一、需求与设计

| 需求编号    | 需求描述                          | 优先级 |
|---------|-------------------------------|-----|
| AUTH-01 | 用户注册（用户名+密码+QQ邮箱+验证码）         | P0  |
| AUTH-02 | 用户登录（用户名+密码）                  | P0  |
| AUTH-03 | 密码重置（通过QQ邮箱验证码）               | P1  |
| AUTH-04 | 会话管理（Servlet HttpSession）     | P0  |
| AUTH-05 | 注册/重置验证码发送（QQ邮箱SMTP）          | P1  |
| AUTH-06 | 登录限流（8次/5分钟）                  | P1  |
| AUTH-07 | 验证码限流（3次/10分钟，间隔 $\geq 3$ 分钟） | P1  |

1. **仅支持QQ邮箱注册** — QQ号格式 `[1-9][0-9]{4,11}@qq.com`，QQ SMTP发送验证码
  - 代码位置：`src/main/java/com/example/chat/common/Validation.java` — `qqEmail()` / `normalizeQqEmail()` 方法
2. **开发模式免发邮件** — `mail.devMode=true`(默认) 时验证码打印到控制台
  - 代码位置：`src/main/java/com/example/chat/auth/QqMailSender.java` — `sendCode()` 方法
3. **注册时自动创建欢迎数据** — 默认好友分组 + 系统消息会话 + 欢迎消息
  - 代码位置：`src/main/java/com/example/chat/auth/AuthDao.java` — `createUser()` 方法
4. **Session-based 认证** — 不使用 JWT，用户ID存储在 `HttpSession` 中
  - 代码位置：`src/main/java/com/example/chat/common/SessionKeys.java` — `CHAT_USER_ID` 常量

## 二、后端设计

```

AuthResource (REST控制器, 94行)
    ↓
AuthService (业务逻辑, 124行)
    ↓
AuthDao (数据访问, 119行) + EmailCodeService (验证码服务, 34行)
    ↓                               ↓

```

MySQL

QqMailSender (SMTP, 55行)  
EmailCodeCooldown (冷却, 19行)

- AuthResource: `src/main/java/com/example/chat/auth/AuthResource.java`
- AuthService: `src/main/java/com/example/chat/auth/AuthService.java`
- AuthDao: `src/main/java/com/example/chat/auth/AuthDao.java`

## 2.2 关键类与方法

### AuthResource — REST 端点

- POST `/api/auth/register/code` — 发送注册验证码
- POST `/api/auth/register` — 注册新用户
- POST `/api/auth/login` — 登录
- POST `/api/auth/logout` — 登出
- GET `/api/auth/me` — 获取当前用户ID
- POST `/api/auth/password-reset/code` — 发送密码重置验证码
- POST `/api/auth/password-reset` — 重置密码

代码位置: `src/main/java/com/example/chat/auth/AuthResource.java`

### AuthService — 核心业务逻辑

- `sendRegisterCode(String qqEmail)` — 发注册验证码前检查邮箱未注册
- `sendResetCode(String qqEmail)` — 发重置验证码前检查邮箱已注册
- `register(RegisterRequest)` — normalize → validate → consume code → hash password → create user
- `login(LoginRequest)` — 获取hash → BCrypt验证 → 检查disabled → 返回User
- `resetPassword>PasswordResetRequest)` — 验证邮箱存在 → 消费验证码 → 更新密码hash

代码位置: `src/main/java/com/example/chat/auth/AuthService.java`

### AuthDao — 数据库操作

- `findByUsername(Connection, String)` — 从 users 表查询用户
- `passwordHashByUsername(Connection, String)` — 获取密码hash
- `createUser(Connection, RegisterRequest, String)` — 事务性创建: 插入user + 创建默认 friend\_group + 创建系统消息conversation + 添加成员 + 插入欢迎消息
- `consumeEmailCode(Connection, String, String, String)` — 原子消费验证码 (标记used=1, 检查过期)
- `saveEmailCode(Connection, String, String, String)` — 插入验证码 (10分钟过期)

代码位置: `src/main/java/com/example/chat/auth/AuthDao.java`

## 2.3 安全设计

- **BCrypt 密码哈希**: 12轮 log\_rounds
  - 代码位置: `src/main/java/com/example/chat/common/PasswordHasher.java`
- **滑动窗口限流**: `ConcurrentHashMap<String, Deque<Long>>`, evict过期时间戳

- 代码位置: `src/main/java/com/example/chat/common/RateLimiter.java`
- 验证码冷却: 两次发送间隔 $\geq 180$ 秒
  - 代码位置: `src/main/java/com/example/chat/auth/EmailCodeCooldown.java`
- 验证码消费: SQL层面原子操作 + 过期检查
  - 代码位置: `src/main/java/com/example/chat/auth/AuthDao.java` — `consumeEmailCode()`

## 三、数据库设计

### 3.1 users 表

| 列名            | 类型           | 约束                       | 说明         |
|---------------|--------------|--------------------------|------------|
| id            | BIGINT       | PK, AUTO_INCREMENT       | 用户ID       |
| username      | VARCHAR(40)  | NOT NULL, UNIQUE         | 用户名        |
| password_hash | VARCHAR(120) | NOT NULL                 | BCrypt哈希   |
| qq_email      | VARCHAR(120) | NOT NULL, UNIQUE         | QQ邮箱       |
| nickname      | VARCHAR(60)  | NOT NULL                 | 昵称         |
| role          | VARCHAR(20)  | NOT NULL, DEFAULT 'USER' | USER/ADMIN |
| disabled      | TINYINT(1)   | NOT NULL, DEFAULT 0      | 禁用标记       |

建表SQL: `src/main/resources/schema.sql` 第4-16行

### 3.2 email\_verification\_codes 表

| 列名         | 类型           | 约束                  | 说明                      |
|------------|--------------|---------------------|-------------------------|
| id         | BIGINT       | PK, AUTO_INCREMENT  | —                       |
| qq_email   | VARCHAR(120) | NOT NULL            | 目标邮箱                    |
| code       | VARCHAR(12)  | NOT NULL            | 6位验证码                   |
| purpose    | VARCHAR(32)  | NOT NULL            | REGISTER/RESET_PASSWORD |
| expires_at | TIMESTAMP    | NOT NULL            | 过期时间(NOW+10min)         |
| used       | TINYINT(1)   | NOT NULL, DEFAULT 0 | 已使用标记                   |

建表SQL: `src/main/resources/schema.sql` 第18-26行

## 四、API 接口设计

### 4.1 POST /api/auth/register/code — 发送注册验证码

```
// Request
{ "qqEmail": "123456@qq.com" }
```

```
// Response (成功)
{ "ok": true, "message": "ok", "data": null }

// Response (频率限制)
{ "ok": false, "message": "请在 120 秒后重试", "data": null }
```

限流：3次/10分钟，冷却间隔180秒 代码位置：

`src/main/java/com/example/chat/auth/AuthResource.java — sendRegisterCode()`

## 4.2 POST /api/auth/register — 注册

```
// Request
{
  "username": "alice",
  "password": "123456",
  "qqEmail": "123456@qq.com",
  "code": "123456",
  "nickname": "Alice"
}

// Response (成功)
{ "ok": true, "message": "ok", "data": 1 } // 返回新用户ID
```

代码位置： `src/main/java/com/example/chat/auth/AuthResource.java — register()`

## 4.3 POST /api/auth/login — 登录

```
// Request
{ "username": "alice", "password": "123456" }

// Response (成功)
{ "ok": true, "message": "ok", "data": 1 } // 返回用户ID

// Response (账号禁用)
{ "ok": false, "message": "Account is disabled.", "data": null }
```

限流：8次/5分钟 代码位置： `src/main/java/com/example/chat/auth/AuthResource.java — login()`

## 4.4 POST /api/auth/logout — 登出

```
// Response
{ "ok": true, "message": "ok", "data": null }
```

代码位置： `src/main/java/com/example/chat/auth/AuthResource.java — logout()`

## 4.5 GET /api/auth/me — 当前用户

```
// Response
{ "ok": true, "message": "ok", "data": 1 }
```

代码位置: `src/main/java/com/example/chat/auth/AuthResource.java` — `me()`

## 4.6 POST /api/auth/password-reset — 重置密码

```
// Request
{ "qqEmail": "123456@qq.com", "code": "123456", "newPassword": "654321" }

// Response
{ "ok": true, "message": "ok", "data": null }
```

代码位置: `src/main/java/com/example/chat/auth/AuthResource.java` — `reset()`

---

# 五、前端设计

## 5.1 页面结构

登录/注册/密码重置三个面板共用一张卡片式界面。

代码位置: `src/main/webapp/index.html` (164行) — `#loginPanel` / `#registerPanel` / `#resetPanel`

## 5.2 核心JS函数

| 函数                                 | 功能                                                                   |
|------------------------------------|----------------------------------------------------------------------|
| <code>sendRegisterCode()</code>    | 调用 <code>/api/auth/register/code</code> , 带冷却倒计时                     |
| <code>handleRegister()</code>      | 校验表单 → 调用 <code>/api/auth/register</code> → 跳转 <code>app.html</code> |
| <code>handleLogin()</code>         | 校验表单 → 调用 <code>/api/auth/login</code> → 跳转 <code>app.html</code>    |
| <code>sendResetCode()</code>       | 调用 <code>/api/auth/password-reset/code</code>                        |
| <code>handleResetPassword()</code> | 调用 <code>/api/auth/password-reset</code>                             |
| <code>switchAuthTab(tab)</code>    | 切换登录/注册/重置面板                                                         |

代码位置: `src/main/webapp/assets/js/auth.js`

## 5.3 UI 特性

- 密码显隐切换按钮
- 验证码60秒倒计时重发
- "记住我30天" 选项
- 装饰性吉祥物动画 (parallax 眼动追踪)

## 六、Request/Response DTO

| DTO                  | 文件路径                                | 字段                                          |
|----------------------|-------------------------------------|---------------------------------------------|
| LoginRequest         | auth/LoginRequest.java (4行)         | username, password                          |
| RegisterRequest      | auth/RegisterRequest.java (4行)      | username, password, qqEmail, code, nickname |
| EmailCodeRequest     | auth/EmailCodeRequest.java          | qqEmail                                     |
| PasswordResetRequest | auth/PasswordResetRequest.java (4行) | qqEmail, code, newPassword                  |

所有请求/响应统一包裹在 `ApiResponse<T>` 中。代码位置：  
`src/main/java/com/example/chat/common/ApiResponse.java` (12行)